AIORI HACKATHON 2026 / PROBLEM STATEMENT PS-011

ArgusASM: Autonomous Attack-Surface Inventory & Drift Sentinel

Level 2 Technical Submission Dossier and Architecture Specification

TRACK	Cybersecurity & Infrastructure Resilience
TEAM	ZeroDayZ
REPOSITORY	aiori-hackathon/A3-PS011-TC116
AUTHORIZATION REF.	AIORI-2026-PS011-AUTH-001
EVALUATION WINDOW	16 Oct – 30 Oct 2026
VERSION / STATUS	1.0 • Submission Freeze

Submission purpose
A technical dossier documenting ArgusASM's authorized scope, passive discovery checks, safety controls, cryptographic state tracking, seeded-issue evaluation, confidence calibration, and operational roadmap.

4	3/3	51/51	0
Documented checks	Seeded faults detected	Automated tests passing	Network calls for blocked scope

00 Submission Deliverables & Verification Matrix

The following artifacts provide reviewers with the live console, demonstration, API surface, machine-readable findings, automated validation, and offline evidence pack.

DELIVERABLE	LINK / LOCATION	VERIFICATION SCOPE & PURPOSE
Live Working Demo	a3-ps-011-tc-116.vercel.app	Production Sentinel Web Console with interactive HUD, topology graph, drift viewer, and dark/light mode.
Walkthrough Video	Watch walkthrough	Demonstration of perimeter discovery, drift injection, and verification.
Presentation Deck	Google Slides presentation	High-level architecture, threat modeling, and defensive engineering approach.
Live Backend API	argus-backend-api-sqrs.onrender.com	FastAPI REST API, Swagger UI at /docs, and live telemetry at /api/telemetry/live.
Executive Audit Report	/api/v1/export/executive-report	Print-ready executive perimeter report with cryptographic Merkle attestation.
OASIS SARIF 2.1.0	/api/v1/export/sarif	Security findings format for GitHub Advanced Security and enterprise SIEMs.
Automated Pytest Suite	tests/ — 51/51 tests passing	100% pass rate in 1.1 seconds, covering scope caps, zero-packet ledger, Merkle chain, and wording lint.
Offline Deliverable Pack	samples/	T0/T1/T2 snapshots, drift reports, SARIF, CSV, JSON, and HTML executive audit report.

01 Executive Abstract & Authorized Scope

Modern hybrid cloud architectures can accumulate unmanaged assets, including unmaintained test subdomains, expired X.509 TLS certificates, exposed debug ports, and orphaned CNAME records pointing to decommissioned third-party cloud buckets. ArgusASM is an autonomous, strictly non-intrusive external attack surface management (ASM) platform designed for the AIORI 2026 PS-011 mandate.

Under cryptographic guardrails, ArgusASM continuously discovers, inventories, and audits an authorized portfolio of public domains and hosts. It establishes a tamper-evident baseline snapshot anchored in a SHA-256 Merkle tree. When perimeter drift occurs, the platform triggers multi-channel alerts, computes stateful set-difference deltas, applies CVSS-calibrated hygiene score deductions, and stages non-destructive remediation advisories behind a mandatory Human-in-the-Loop (HITL) governance gate.

1.1 Authorized Scope Boundary

The platform enforces a hard boundary of no more than 20 public domains and 10 public hosts. Requests exceeding these limits are blocked by the pre-flight parser before any network packets are dispatched.

SCOPE CONTROL	CONFIGURED VALUE
Primary zone	aiori.lab (authoritative CoreDNS lab zone)
Approved domain cap	20 maximum; active portfolio: 15 domains
Approved host cap	10 maximum; active portfolio: 8 hosts
Permitted port whitelist	{22, 53, 80, 443, 8080}

1.2 Formal Authorization Statement

This document certifies that ArgusASM is authorized by AIORI Infrastructure & Security Operations to perform passive, read-only reconnaissance against the lab assets cataloged in `approved_scope.json` between **2026-10-01T00:00:00Z** and **2026-11-30T23:59:59Z**. Active exploitation, credential brute-forcing, denial-of-service, third-party cloud bucket claiming, and out-of-scope targeting are strictly prohibited.

02 Architecture & Four Documented Checks

ArgusASM separates discovery, state tracking, and user visualization into asynchronous modules. The four documented checks are:

Check 1 — Public DNS Inventory

Resolves RFC 1035/2181 A, AAAA, CNAME, MX, TXT, and NS records with 3.0-second socket timeouts. Traverses CNAME chains to a maximum depth of three hops. Read-only; zone transfers (AXFR) are prohibited.

Check 2 — Extended TLS Inspector

Validates X.509 certificates (RFC 5280). Identifies expired certificates, certificates expiring in fewer than 14 days, self-signed certificates, weak RSA keys under 2048 bits, and deprecated TLS 1.0/1.1 protocols. Uses a non-intrusive handshake only.

Check 3 — Permitted Service Auditor

Connects only to whitelisted ports {22, 53, 80, 443, 8080}. Captures service banners without fuzzing and detects unapproved shadow services, such as Werkzeug debug on port 8080.

Check 4 — Potential Dangling DNS Detector

Analyzes CNAME targets against cloud-provider patterns (AWS S3, Azure Web Apps, and GitHub Pages). Flags potential unallocated buckets using HTTP 404 NoSuchBucket fingerprints. It never attempts to claim or register orphaned resources.

Design principle: discovery is passive and bounded; the system identifies and reports potential exposures without attempting exploitation or resource takeover.

03 Non-Exploitation Policy & Safety Guardrails

Out-of-scope targets are rejected during pre-flight with zero network calls. The rejection is recorded in SQLite through `RequestLedger`. The following entry illustrates a scope violation:

```
{
  "id": "REQ-7B8A91C2D4E0",
  "timestamp": "2026-10-25T13:21:40.104Z",
  "target": "external-attacker.com",
  "probe_type": "DNS",
  "status": "ScopeViolation",
  "network_calls_made": 0,
  "duration_ms": 0.1,
  "response_summary": "BLOCKED BY SCOPE GUARDRAIL: Target not in approved scope.",
  "authorization_ref": "AIORI-2026-PS011-AUTH-001"
}
```

Emergency Kill Switch (R■)

Invoking `POST /api/v1/killswitch` halts all in-flight probing threads within less than 10 milliseconds.

Human-in-the-Loop (HITL) Gate

All High and Critical findings require explicit human sign-off before any remediation script or firewall change can be dispatched.

04 Stateful Change Detection, Snapshots & Merkle Chain

Perimeter state is captured as versioned JSON snapshots: `snapshots/T0.json`, `T1.json`, and `T2.json`. Each snapshot embeds `scope_sha256`—the SHA-256 hash of `approved_scope.json`—and a 32-byte SHA-256 Merkle root computed across canonicalized asset records.

4.1 Merkle Hash Chain Linking

```
MerkleRoot■ = SHA256(Leaves■ || MerkleRoot■■■)
```

This linking scheme is intended to make retroactive changes to historical observations detectable because mutation would break the cryptographic chain.

4.2 Stateful Drift Delta Algorithm

`Delta = Current \ Baseline`. The system categorizes ten typed drift events and uses a two-observation confirmation rule to filter transient network jitter.

NEW_SERVICE	**REMOVED_SERVICE**
EXPIRED_CERT	**CERT_EXPIRING**
CERT_RESOLVED	**DNS_RECORD_CHANGED**
DANGLING_DNS_CANDIDATE	**DANGLING_DNS_RESOLVED**
ASSET_ADDED	**ASSET_REMOVED**

05 Seeded-Issue Detection Results

The multi-container lab testbed was evaluated against three seeded faults and one healthy control host. Results are reported below as documented in the submission dossier.

SEED / HOST	TARGET ASSET	SEEDED CONDITION	EXPECTED	OBSERVED	SCORE IMPACT
TEST-SEED-01	legacy.aiori.lab:443	Expired TLS certificate	EXPIRED_CERT	**Detected (100%)**	–35 points
TEST-SEED-02	dev-edge.aiori.lab:8080	Unauthorized port 8080	NEW_SERVICE	**Detected (100%)**	–25 points
TEST-SEED-03	test-s3.aiori.lab	Orphaned S3 CNAME	DANGLING_DNS	**Detected (100%)**	–30 points
Control Host A	api.aiori.lab:443	Healthy production host	Clean posture	**0 false positives**	0 deductions

100.0%	**100.0%**	**100.0%**
Recall: 3 of 3 seeded faults detected	Precision: no false positives on control host	Out-of-scope requests blocked with zero network calls

HITL governance: 100% of findings were staged for operator review.

06 False-Positive Analysis & Confidence Calibration

To reduce alert fatigue and score distortion, ArgusASM applies the following mitigation heuristics:

- **Wildcard DNS zones.** Resolves a random UUID subdomain. If active, the domain is flagged `WILDCARD_ACTIVE` and generic DNS alerts are down-weighted to LOW confidence.
- **CDN / reverse-proxy detection.** Identifies Cloudflare, Akamai, and Fastly headers (Server/Via) and suppresses false port alerts.
- **Staging self-signed handling.** Uses host role in `approved_scope.json`; downgrades staging self-signed certificates to INFO.
- **Generic 404 vs provider error.** Requires a provider-specific signature (`NoSuchBucket`); generic 404 responses receive LOW confidence.
- **Score deduction caps (R■).** Expired TLS deductions are capped at –40 points, open ports at –35 points, and dangling DNS at –40 points.

Hygiene Score Progression

SNAPSHOT	STATE	HYGIENE SCORE
T0	Baseline	**96 / 100**
T1	Drifted	**68 / 100**
T2	Remediated	**96 / 100**

07 Conclusion, Operational Impact & Roadmap

7.1 Operational Impact

ArgusASM transforms attack-surface inventory from an ad-hoc scanning exercise into a continuous, deterministic, and cryptographically provable sentinel. By combining RFC-compliant passive inspection with SHA-256 Merkle provenance, enterprise security teams can identify shadow exposures while avoiding service disruption.

7.2 Stated Limitations

Passive inspection cannot confirm whether an apparently unallocated cloud bucket is internally reserved by a cloud provider. Scans remain strictly bounded by `approved_scope.json` and do not perform internet-wide sweeps.

7.3 Delivered Level 2 Features & Regional Roadmap

The dossier reports the following Level 2 differentiators as delivered and operational: automated SARIF v2.1.0 export, CSV spreadsheets, one-click executive HTML reports, passive Certificate Transparency monitoring, and simulation controllers. For the regional finals in November 2026, the team plans to extend Post-Quantum Cryptography (PQC) readiness tracking (NIST FIPS 203/204) and distributed multi-cloud edge probe nodes.